

Security Remediation — R2 → R3

R2 weakness	R3 remediation	Verified
Format-only pilot code (any matching string granted access)	Removed entirely; access requires server-verified auth + MFA + entitlement	Frontend-security + prohibited-pattern gates
Client-side pilot-plan activation via localStorage	Backend is authoritative; localStorage plans cannot launch the app	R2-migration suite (18/18)
Operations Console gated on Google email domain only	Supabase session + AAL2 + active internal role (server-verified)	Frontend-security suite
No MFA	Mandatory TOTP (AAL2) for pilot users, console, and privileged actions	Local (staging E2E pending)
No org isolation enforcement	RLS default-deny; per-org policies; internal_notes column revoked	RLS suite 26/26 on real Postgres
Self-approved pilot registration	Invitation-only; admin-controlled; single-use/email/org/role-bound	Local (staging E2E pending)

Residual risks / honest limitations

- Local plan/role values still exist for Demo Mode UX; they cannot open real data (server decision required), but a sophisticated user can alter their own browser state — which is why real-data access is a **server** decision, revalidated ≤ 300 s.
- Revocation propagation is not instantaneous; see incident-response and known-limitations for the stated maximum delay.
- Staging behaviors (MFA, invitations, revocation timing) are **NOT VALIDATED IN STAGING** until the E2E runs.